

Отчёт о приоритетных правилах корреляции

Резюме

В рамках расследования инцидента были разработаны правила корреляции для предотвращения подобных атак. Данный отчёт содержит анализ приоритетности правил на основе их критичности и места в цепочке атаки.

Классификация правил по приоритетам

Критический приоритет (P1)

1. Обнаружение фишинговых писем с вложениями

MITRE ATT&CK: T1566.001 (Phishing: Spearphishing Attachment)

Этап атаки: Initial Access (Первоначальный доступ)

Обоснование приоритета: - Фишинг является наиболее частым вектором начального проникновения в корпоративные сети. Обнаружение на этом этапе позволяет предотвратить развитие атаки, защитить конфиденциальные данные и избежать финансовых и репутационных потерь.

Условия срабатывания: - Письмо с вложением, имеющим расширение исполняемого файла (.exe, .scr, .msi, .com и др.). Правило срабатывает на события log_type: email с has_attachment: true и attachment_name: *.exe

2. Обнаружение запуска подозрительных процессов

MITRE ATT&CK: T1204.002 (User Execution: Malicious File)

Этап атаки: Execution (Выполнение)

Обоснование приоритета: Запуск вредоносных файлов из нестандартных мест (например, папка Downloads) является прямым признаком атаки. Раннее обнаружение позволяет изолировать хост до начала бокового перемещения и минимизировать ущерб

Условия срабатывания: Событие event_id: 1 (запуск процесса) с process_path: *Downloads*, process_name: *.exe и parent_process_name: explorer.exe (или аналогичными признаками ручного запуска пользователем)

3. Обнаружение бокового перемещения

MITRE ATT&CK: T1021.001 (Remote Services: Remote Desktop Protocol), T1021.002 (Remote Services: SMB/Windows Admin Shares)

Этап атаки: Lateral Movement (Боковое перемещение)

Обоснование приоритета: Компрометация контроллера домена или файлового сервера является критическим инцидентом. Обнаружение латерального движения позволяет оперативно остановить распространение атаки и сохранить контроль над инфраструктурой, предотвращая кражу данных и полную компрометацию домена

Условия срабатывания: Обнаружение RDP-подключений (event_id: 4624 с logon_type: 10 от рабочей станции к серверу) или доступа к административным шарам (event_id: 5140 с share_name: C\$ или ADMIN\$)

4. Обнаружение эксфильтрации данных

MITRE ATT&CK: T1048 (Exfiltration Over Alternative Protocol)

Этап атаки: Exfiltration (Эксфильтрация)

Обоснование приоритета: Утечка конфиденциальных данных (финансовых, кадровых, стратегических) наносит прямой ущерб бизнесу: финансовые потери, репутационный ущерб, регуляторные штрафы. Это одно из самых критичных событий, требующее немедленного реагирования

Условия срабатывания: Исходящие соединения на внешние IP-адреса с большим объёмом переданных данных (bytes_sent > 10 MB), особенно если они направлены на известные C2-серверы или домены

Высокий приоритет (P2)

5. Обнаружение модификации реестра

MITRE ATT&CK: T1547.001 (Boot/Logon Autostart Execution: Registry Run Keys)

Этап атаки: Persistence (Закрепление)

Обоснование приоритета: Закрепление в системе (автозагрузка) позволяет злоумышленнику сохранять доступ даже после перезагрузки. Важно для обнаружения, но само по себе не является критичным, если нет других признаков атаки. Требуется контекста для подтверждения

Условия срабатывания: Модификация ключей реестра Run, RunOnce (event_id: 13 с registry_key: *Run*), особенно если в команде указаны нестандартные пути или процессы

6. Обнаружение разведки через системные утилиты

MITRE ATT&CK: T1087.001 (Account Discovery: Local Account), T1016 (System Network Configuration Discovery), T1033 (System Owner/User Discovery), T1057 (Process Discovery), T1049 (System Network Connections Discovery)

Этап атаки: Discovery (Разведка)

Обоснование приоритета: Разведка указывает на подготовку к атаке, но сама по себе не наносит ущерба. Позволяет выявить атаку на ранней стадии, но требует дополнительного контекста (например, последовательность запуска нескольких утилит за короткое время) для подтверждения.

Условия срабатывания: Последовательный запуск команд net.exe, ipconfig.exe, whoami.exe, tasklist.exe, netstat.exe (event_id: 1) в течение короткого промежутка времени (например, 2–5 минут)

Средний приоритет (P3)

7. Обнаружение очистки логов

MITRE ATT&CK: T1070.004 (Indicator Removal on Host: Clear Windows Event Logs)

Этап атаки: Defense Evasion (Соккрытие следов)

Обоснование приоритета: Очистка логов это признак завершающей стадии атаки (заметание следов). Важна для расследования и восстановления хронологии событий, но не позволяет предотвратить ущерб, если не сработали другие правила. Имеет низкий приоритет для оперативного реагирования

Условия срабатывания: Запуск утилиты wevtutil.exe с аргументом cl (очистка журналов) на любом хосте (process_name: wevtutil.exe и process_command_line: *cl*)

Рекомендации по внедрению

Фаза 1 (Немедленно):

Внедрить правила P1:

- Обнаружение фишинговых писем с вложениями
- Обнаружение запуска подозрительных процессов
- Обнаружение латерального движения (RDP, SMB)
- Обнаружение эксфильтрации данных

Эти правила закрывают критические этапы атаки и позволяют предотвратить основные бизнес-риски.

Фаза 2 (1-2 недели):

Внедрить правила P2:

- Обнаружение модификации реестра
- Обнаружение разведки через системные утилиты

Эти правила помогают выявить подготовку к атаке и закрепление в системе, повышая общую защищённость.

Фаза 3 (1 месяц):

Внедрить правило P3:

- Обнаружение очистки логов

Это правило важно для полноты расследования и сбора доказательств, но не является первоочередным для оперативного реагирования.

Заключение

Разработанные правила корреляции охватывают все ключевые этапы атаки: от первоначального проникновения через фишинг до кражи данных и сокрытия следов. Приоритеты распределены на основе бизнес-рисков: P1-правила направлены на предотвращение критических событий (фишинг, исполнение, перемещение, эксфильтрация), P2 — на раннее обнаружение подготовки и закрепления, P3 — на поддержку расследования. Поэтапное внедрение позволит минимизировать нагрузку на SOC и обеспечить оперативное закрытие основных угроз. Все правила протестированы на имеющихся логах инцидента и доказали свою эффективность.